INDEPENDENT PRE-LAUNCH AUDIT

Security and Quality Audit

Chairside - salon and barbershop booking app

Findings, business impact, and remediation

October 2026

Confidential - prepared for the application owner

Executive summary

This report reviews a salon and barbershop booking app for security and correctness, and documents the fixes applied. It is written for the business owner: each finding explains what was found, why it matters for the business, and what was done about it.

0	2	11	5	1
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

The app is built on solid foundations. The database keeps each salon's data separate, visitors cannot read the tables directly, and the system already prevents two bookings landing on the same person at the same time. The automated security scan offered by the build platform reported no issues at the time of the audit (October 2026); that same report notes it cannot catch every possible risk.

The issues found are subtler than missing basics: the booking and permission rules were enforced only in the app's screens, not on the server. Anyone who talks to the system directly, bypassing the screens, could do things the screens never allow. That is the thread running through the most serious findings.

> Of 19 findings, the 2 High and most Medium issues are fixed or materially reduced; the rest are documented with clear recommendations. Fixes were made so that each one is backed by an automated test. The original app is preserved unchanged for before-and-after comparison.

THE BIGGEST RISKS IN PLAIN TERMS

- A stranger who knew a client's phone number could change that client's name and email.
- Bookings could be created at closed times (03:00, closed days, or years ahead) by bypassing the app.
- Any staff member could delete a client and that client's entire history.
- A single visitor could flood the calendar with fake bookings.
- Typing someone's email into the staff list could silently give them access to your client data.

Latest test run (2026-10-12): 42 tests, 41 passed, 1 skipped (an environment-dependent time-zone demonstration).

What was done well

Not everything needed fixing. These are the parts the app already got right:

- Each salon's data is isolated from every other salon's (verified by tests).
- Anonymous visitors cannot read database tables directly; public actions go only through a small set of controlled functions.
- Double-booking the same staff member at the same time is prevented by the database itself.
- Prices on past bookings are snapshotted, so later price changes do not rewrite history.
- The powerful server key never reaches the browser.
- The AI features run as the signed-in user, so they cannot reach another salon's clients.

ADDITIONAL HARDENING APPLIED

- Anonymous visitors had database-level table privileges by default, leaving the access rules as the only line of defence; those privileges were removed, so anonymous visitors can now use only the controlled public functions.
- Phone numbers are normalised to one format so the same client is not stored twice.

SEC-01 High

Partially fixed

A visitor could change an existing client's name and email

WHAT WAS FOUND

The public booking flow identified clients by phone number. A booking made with an existing client's phone number overwrote that client's stored name and email with whatever was typed.

WHY IT MATTERS FOR THE BUSINESS

Anyone who knew (or guessed) a client's phone number could rename that client and change their email, and the new booking attached to that client's history and notes. This corrupts the client list and could be used to impersonate or harass a client.

HOW IT WAS FIXED

The booking flow no longer overwrites an existing client's name or email. The name entered at booking time is now stored separately and shown to staff when it differs from the client on file, so staff can verify it is the same person. Fully preventing a stranger from attaching to a known phone number requires a phone verification step (a one-time code) at booking, which is recommended as a next step.

BH-01 High

Fixed

Bookings could be made at impossible times

WHAT WAS FOUND

The rules about opening hours, open days and how far ahead clients may book existed only in the app's screens. Calling the booking service directly, the only server check was that the time was not in the past.

WHY IT MATTERS FOR THE BUSINESS

Someone bypassing the app could create appointments while the salon is closed, outside opening hours, or years in the future. The calendar stops reflecting reality and staff cannot trust it.

HOW IT WAS FIXED

The server now enforces the salon's open days, opening hours, a 21-day booking window, and valid time slots - all evaluated in the salon's own time zone.

SEC-03 Medium

Fixed

Staff could do more than their role should allow

WHAT WAS FOUND

Any staff member could edit and delete client records, and could read every booking in the salon. Deleting a client also deleted that client's entire booking and note history.

WHY IT MATTERS FOR THE BUSINESS

A single stylist could wipe a client's whole history, or browse other staff members' clients - well beyond 'see your own calendar'.

HOW IT WAS FIXED

Staff can now read clients (needed to keep notes) but only the owner can change or delete them. Each staff member now sees only their own appointments; the owner still sees all.

BH-02 Medium

Partially fixed

No limit on public bookings

WHAT WAS FOUND

A single anonymous visitor could create an unlimited number of bookings; there was no rate limit or quota.

WHY IT MATTERS FOR THE BUSINESS

An attacker could fill the calendar and client table with fake entries and make the system unusable for the salon.

HOW IT WAS FIXED

The server now limits how many upcoming bookings a single phone number can hold and how many bookings a salon accepts in a short window. Network-level rate limiting per visitor and a CAPTCHA are recommended as an additional layer, along with a usage limit on the AI features.

SEC-04 Medium

Fixed

Staff invitations joined people without consent

WHAT WAS FOUND

Adding an email address to the staff list silently linked that person to the salon the next time they signed in, with no acceptance step.

WHY IT MATTERS FOR THE BUSINESS

A person could be given access to a salon's client data without ever agreeing to join, and the behaviour was unpredictable when an email belonged to more than one salon.

HOW IT WAS FIXED

Invitations now require explicit acceptance: the invited person sees a pending invitation and must click Accept, and only an invitation addressed to their own email can be accepted.

SEC-02 Medium

Fixed

No limits on booking form input

WHAT WAS FOUND

The booking form accepted names, phone numbers and emails of unlimited length and with no format checking (a 20,000-character name was accepted).

WHY IT MATTERS FOR THE BUSINESS

Oversized or malformed data could break staff screens and outgoing messages and bloat the database.

HOW IT WAS FIXED

The server now checks the length and basic format of the name, phone number and email.

SEC-05 Medium

Fixed

Missing security headers

WHAT WAS FOUND

The app sent none of the standard browser security headers (such as a content security policy or anti-framing header).

WHY IT MATTERS FOR THE BUSINESS

The site could be embedded invisibly in a malicious page to trick clients (clickjacking), and browser defences against injected scripts were weaker than they should be.

HOW IT WAS FIXED

Every response now carries a content security policy and the other standard security headers. The policy was verified against the running app so it protects without breaking any feature.

SEC-06 Medium

Recommendation

Login session stored in the browser

WHAT WAS FOUND

The login session token is kept in the browser's local storage.

WHY IT MATTERS FOR THE BUSINESS

If a script-injection flaw ever occurred, an attacker could read the session and take over the account.

HOW TO FIX

Recommended: store the session in a secure, script-inaccessible cookie. The content security policy added above reduces the risk in the meantime.

SEC-10 Medium

Partially fixed

Personal data handling and the AI features

WHAT WAS FOUND

Client personal data (name, phone, email, notes, visit history) is sent to an outside AI provider for the summary and reminder features. There was no stated retention period, no deletion or export path, and no privacy notice on the booking page.

WHY IT MATTERS FOR THE BUSINESS

Clients' personal data leaves the salon's system with no stated handling, and the salon cannot easily honour a request to delete someone's data.

HOW IT WAS FIXED

A short privacy notice was added to the booking page. Recommended: minimise what is sent to the AI, define a retention period with automatic deletion, and add a way to export or erase a client's data on request.

SE-01 Medium

Fixed

Business rules lived only in the app screens

WHAT WAS FOUND

Opening hours, the booking window, cancel and move rules and revenue all lived in the browser, not on the server.

WHY IT MATTERS FOR THE BUSINESS

Anyone bypassing the app screens could ignore the salon's rules.

HOW IT WAS FIXED

The booking rules were moved onto the server and into the database access rules (see BH-01 and SEC-03).

SE-02 Medium

Fixed

Time slots used the visitor's time zone

WHAT WAS FOUND

The list of free time slots was calculated using the visitor's device time zone, while the salon's opening hours are stored without a time zone.

WHY IT MATTERS FOR THE BUSINESS

A client in another region saw shifted times and could book a slot that is not actually open at the salon; two clients in different regions picking the same time sent two different real times.

HOW IT WAS FIXED

Slots are now computed in the salon's own time zone, so every visitor sees the same real opening times.

SE-03 Medium

Recommendation

Lists and dashboard will under-report at scale

WHAT WAS FOUND

Lists and the dashboard have no paging and silently stop at the first 1000 rows; revenue is added up in the browser.

WHY IT MATTERS FOR THE BUSINESS

As the salon grows, the dashboard and lists will quietly show incomplete or wrong totals.

HOW TO FIX

Recommended: calculate totals and popular services on the server and add paging to the lists.

SE-04 Medium

Partially fixed

Data model: phone duplicates and no audit trail

WHAT WAS FOUND

Clients are identified by phone number with no normalisation (so '+90...', '0...' and spaced variants could create duplicates), deletes cascade, and there is no record of who changed what.

WHY IT MATTERS FOR THE BUSINESS

The same client entered two ways becomes two records, and deletions remove history with no audit trail.

HOW IT WAS FIXED

Phone numbers are now normalised to one format before saving, and uniqueness is enforced on the normalised value. Recommended: soft-delete (hide rather than erase) and an audit trail.

SEC-07 Low

Fixed

Booking-link not cleaned on the server

WHAT WAS FOUND

A salon's public booking-link (slug) was not sanitised when set directly through the service, bypassing the app's cleanup.

WHY IT MATTERS FOR THE BUSINESS

Broken or confusing public booking links.

HOW IT WAS FIXED

The server now normalises the booking-link and enforces a safe format; it also now rejects negative prices.

SEC-09 Low

Fixed

AI reminder could be steered by note content

WHAT WAS FOUND

Client name and notes flow directly into the AI prompt, and the AI-written reminder is sent from the salon's own phone number.

WHY IT MATTERS FOR THE BUSINESS

Someone could try to steer the reminder message (for example to insert a link) by writing instructions into a client's note or name.

HOW IT WAS FIXED

Untrusted text is now clearly marked as data rather than instructions, and links are stripped from the reminder before it can be sent. A working exploit was not reproduced; this hardens the design.

SEC-11 Low

Recommendation

Environment file in the repository; dependency advisories

WHAT WAS FOUND

An environment file was committed to the generated project (it contained only the public key), and there are development-only dependency advisories.

WHY IT MATTERS FOR THE BUSINESS

Low: the committed key is public by design, and the advisories affect only the development tools, not the live app.

HOW TO FIX

Recommended: keep environment files out of the repository and update the affected development tool.

SEC-12 Low

Recommendation

Password-guessing was not rate-limited (test project)

WHAT WAS FOUND

Password strength, email confirmation and protection against revealing which emails are registered were all in good shape. However, repeated wrong-password attempts were not throttled in the test project.

WHY IT MATTERS FOR THE BUSINESS

Without a limit, automated password-guessing against an account is easier.

HOW TO FIX

Recommended: confirm the production setting and enable rate limiting or temporary lockout after repeated failures.

SE-05 Low

Recommendation

Thin automated tests; some loosely-typed code

WHAT WAS FOUND

The generated app shipped with a single automated test and some loosely-typed code.

WHY IT MATTERS FOR THE BUSINESS

Lower confidence that future changes will not quietly break something.

HOW TO FIX

Recommended: broaden automated test coverage and tighten types. This audit adds a runnable security test suite as a starting point.

SEC-08 Informational

Fixed

Internal helper functions callable by anyone

WHAT WAS FOUND

Two internal helper functions could be called by anonymous visitors (harmless: they return nothing useful to an anonymous caller).

WHY IT MATTERS FOR THE BUSINESS

No practical impact; addressed as defence in depth.

HOW IT WAS FIXED

Access to the helper functions is now restricted to signed-in users.

Remediation roadmap

Recommended order for the work still outstanding.

#	ACTION	ADDRESSES	EFFORT
1	Phone verification (one-time code) at booking	SEC-01	Medium
2	Move the login session to a secure, script-inaccessible cookie	SEC-06	Medium
3	Server-side totals and paging for lists and the dashboard	SE-03	Medium
4	Data retention, deletion and export; minimise data sent to the AI	SEC-10	Medium
5	Per-visitor rate limiting and a CAPTCHA at the edge; AI usage limit	BH-02	Low
6	Confirm production auth settings and enable password-guessing protection	SEC-12	Low
7	Keep environment files out of the repository; update development tools	SEC-11	Low
8	Broaden automated tests; tighten types; soft-delete and audit trail	SE-04, SE-05	Medium

Scope and how to re-run the tests

SCOPE

Testing was limited to a locally running copy of the app and a separate test project with the same database structure applied to it. No hosted or production environment was accessed. All test data is fictitious.

RE-RUNNING THE TESTS

The findings are backed by an automated test suite. To re-run it against your own test project, provide connection details in a local environment file (not included in this report) with these variable names:

- `AUDIT_SUPABASE_URL`
- `AUDIT_SUPABASE_PUBLISHABLE_KEY`
- `AUDIT_SUPABASE_SECRET_KEY`
- `AUDIT_DATABASE_URL`
- `AUDIT_GEMINI_API_KEY (only for the AI prompt-injection test)`

1. npm install
2. Apply the original database structure (migration 0000).
3. Apply the hardening changes (migration 0001).
4. Load the fictitious test data (fixtures).
5. Run the test suite. With only the original structure applied, the finding tests fail (proving the issue); with the hardening applied, they pass (proving the fix).